



MASTER OF SCIENCE
IN ENGINEERING

TSM_SecIndOpT

Threat models in OT systems (I)

Version: 2.0, by T. Mesot

whoami



Titouan Mesot - IT/OT Security Specialist

EXPERTISE: OT/ICS Cybersecurity, Security Testing, Embedded Systems

BACKGROUND: BSc. in Telecommunication (Networks and Security)

KEY INDUSTRIES: Utilities, Industrial systems, Mobility, Medical

CertX is the foundation of its ecosystem, and the First Swiss Certification Body for Functional Safety and Cyber Security accredited by Swiss Accreditation Service (SAS) with international validity

CertX AG

Passage du Cardinal 5
1700 Fribourg
Switzerland



CertX Solutions is the consultancy branch from CertX ecosystem, sharing top-level expertise and background experiences with industrial customers for helping them complying with best security, safety and AI practices aiming to reach compliance with regulatory framework and State-of-the Art

CertX Solutions AG

Passage du Cardinal 5
1700 Fribourg
Switzerland



Threat models in OT systems – Agenda

MODULE A

Introduction to Threat Analysis & Risk Assessment [TARA]

Threat Analysis & Risk Assessment introduction & walkthrough

- Risk assessment scope: System vs Product perspective
- Key concepts: Security-by-design, holistic approach, defense-in-depth...
- TARA primitives & relationships
- TARA walkthrough part I
 - System definition & security attributes
 - Damage scenario & impact rating
 - Threat scenario identification

Medical environment use case – Domestic medical device – Part 1

- System under Considerations [SuC] definitions & damages scenario
- Threat scenario identification

MODULE B

Applied Threat Analysis & Risk Assessment [TARA]

Threat Analysis & Risk Assessment walkthrough follow-up

- TARA walkthrough part II
 - Attack path analysis & feasibility rating
 - Risk value computation & treatment decisions

Medical environment use case – Domestic medical device – Part 2

- Attack trees & feasibility rating
- Risk values & alternative treatment

Wrap-up and challenges

- Upcoming regulations & challenges

Medical environment use case – Professional medical device

[optional homework]



Anthropic's Claude Mythos Finds Thousands of Zero-Day Flaws Across Major Systems

📅 Apr 08, 2026 Artificial Intelligence / Secure Coding



N. Korean Hackers Spread 1,700 Malicious Packages Across npm, PyPI, Go, Rust

📅 Apr 08, 2026 Malware / Threat Intelligence

The North Korea-linked persistent campaign known as Contagious Interview has spread its tentacles by publishing malicious packages targeting the Go,...

TLP: CLEAR

Security Advisory: Axios NPM Package Compromise (March 31, 2026)

On March 31, 2026, the popular 'axios' HTTP client library was compromised through a maintainer account hijack. An attacker gained access to the npm account of a lead maintainer and published malicious versions containing a cross-platform Remote Access Trojan (RAT).

Created: 31.03.2026 at 10:54



Fortinet Patches Actively Exploited CVE-2026-35616 in FortiClient EMS

📅 Apr 05, 2026 Vulnerability / API Security

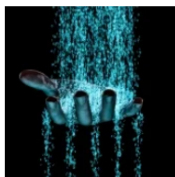
Fortinet has released out-of-band patches for a critical security flaw impacting the wild. The vulnerability,...

VDE-2026-011

CODESYS Control V3 - Untrusted boot application

The CODESYS Control runtime system provides a user management mechanism with m Administrators and Developer groups are intended to load or debug applications on ...

🔴 CVE-2025-41660



SECURITY

Snowflake customers hit in data theft attacks after SaaS integrator breach

Over a dozen companies have suffered data theft attacks after a SaaS integration provider was breached and authentication tokens stolen.

👤 LAWRENCE ABRAMS 📅 APRIL 07, 2026 ⌚ 03:39 PM 💬 0

And now ... what ?

- PANIC ?
- DENY ?
- ... ?

IT / OT Security vs Product Security...

[IT/OT] System cyber security

- Stakeholders: Internal actors & suppliers
- Objectives: Business continuity & resilience
- Regulatory context: NIS2, GDPR in EU. In Switzerland ICT Minimum for certain industries.
- Main challenges:
 - Standard IT security practices vs OT considerations – What to reuse, extend, adjust, redefine ?
 - Assets heterogeneity & legacy parts
 - Patch management
 - “Do not be only seen as a cost center”

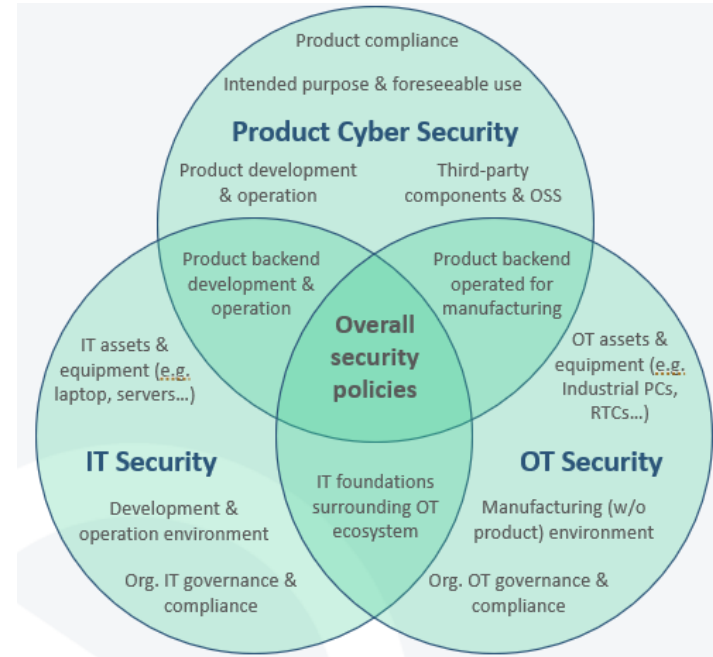
Disclaimer: This course part will mostly be oriented on product security cases

Product cyber security

- Stakeholders: Product integrators & end users
- Objectives: Product liability
- Regulatory context: Legally binding for any products with digital elements sold in EU
- Main challenges:
 - Integration of cyber security considerations into existing product development & operation processes
 - Transversal to organizational units (e.g. product on the field vs connected services)
 - Compliance complexity
 - Decommissioning of products – who is responsible (?)

IT / OT Security vs Product Security...

- Same foundations
- Product are increasingly connected so policies cross domains



Threat Analysis & Risk Assessment - WHY

Defining and prioritizing what must be protected based on risk and threat analysis

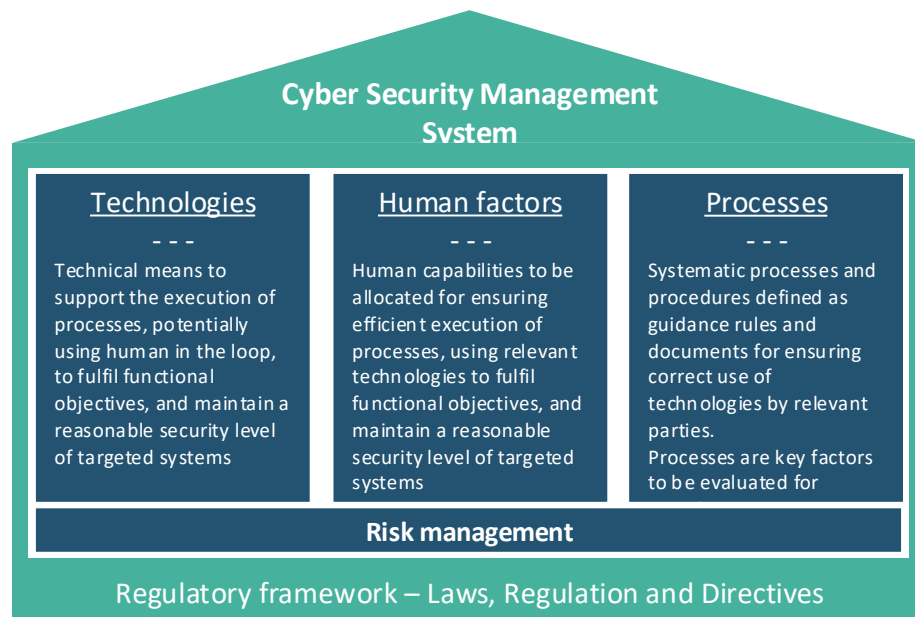
- What are my key assets & what potential consequences / damages ?
- What are the attack vectors against my assets ?
- How & on what invest effort to reach a reasonable security posture ?
- What security measures for which improvement ?
- What to monitor for securing a continuous acceptable residual risks

... and what security principles are we willing to follow ?

Threat Analysis & Risk Assessment - WHY

Targeted cyber security principle: Holistic approach

- Sometimes a technology security measure is not efficient
- Think of all possible options:
 - Human factors
 - Processes
 - Technologies
- Eg: Intel ME vulnerabilities are hard to fix ... maybe just disable the feature at provisioning is enough ?



Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Security by design

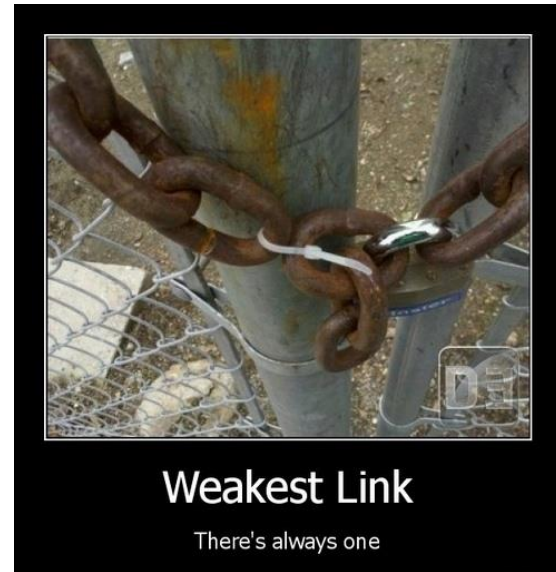
Integrate cyber security measures & controls

- Right from the beginning of development to provide / use security capabilities
- Where, when and how it matters, being pragmatic
- In the most efficient way to reduce risk levels down to an acceptable level
- Keeping an up-to-date visibility over current threat landscape

Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Secure the weakest link

- How to Identify the weakest link ?
- If a vulnerability affects a security control, how does it impact the overall risk, and which risks are affected?
- What is the most effective way to mitigate the weakest link once identified?



Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Defense in depth

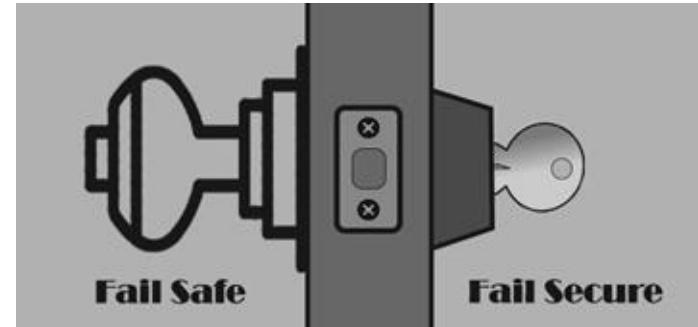
- Is one security control enough to mitigate the risk ?
- Which layers of controls mitigate which risks ?
- How many weaknesses can be accepted before increasing the risk ?



Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Fail secure

- Identify essential functions
- Identify safety related functions
- Considering potential conflicts with other discipline (e.g., Functional Safety)
- FuSa: If a drone detect a hardware failure, we must try to land or come back to landing area ?
- CyberSec: If a drone detect a radio attack, can we try to land ?

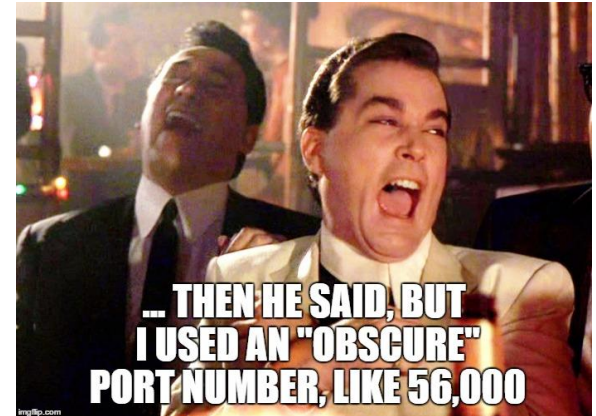


<https://ms.codes/blogs/cybersecurity/fail-safe-defaults-fail-secure-cybersecurity>

Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Assume secrets not safe

- Doing the best by assuming the worst
 - Treats secret exposure as realistic threat, not edge cases
 - Evaluate impact after secret compromise
- Forget any security-by-obscurity principles
 - Reuse security catalogue from well-known sources
- Enforce lifecycle controls on secrets
 - Key rotation / expiration
 - Secure update
 - ...



<https://imgflip.com/i/1jgg5c>

Threat Analysis & Risk Assessment – WHY

Targeted cyber security principle: Monitor & audit

- Threats will evolve with time; TARA must do so !
- Supports forensic readiness
- Drives integrity & trust in audit data
- Use monitoring as a security measure



"MAYBE WE SHOULD TRY A DIFFERENT
SECURITY APPROACH THIS YEAR."

<https://www.jklossner.com/>

Threat Analysis & Risk Assessment – WHY

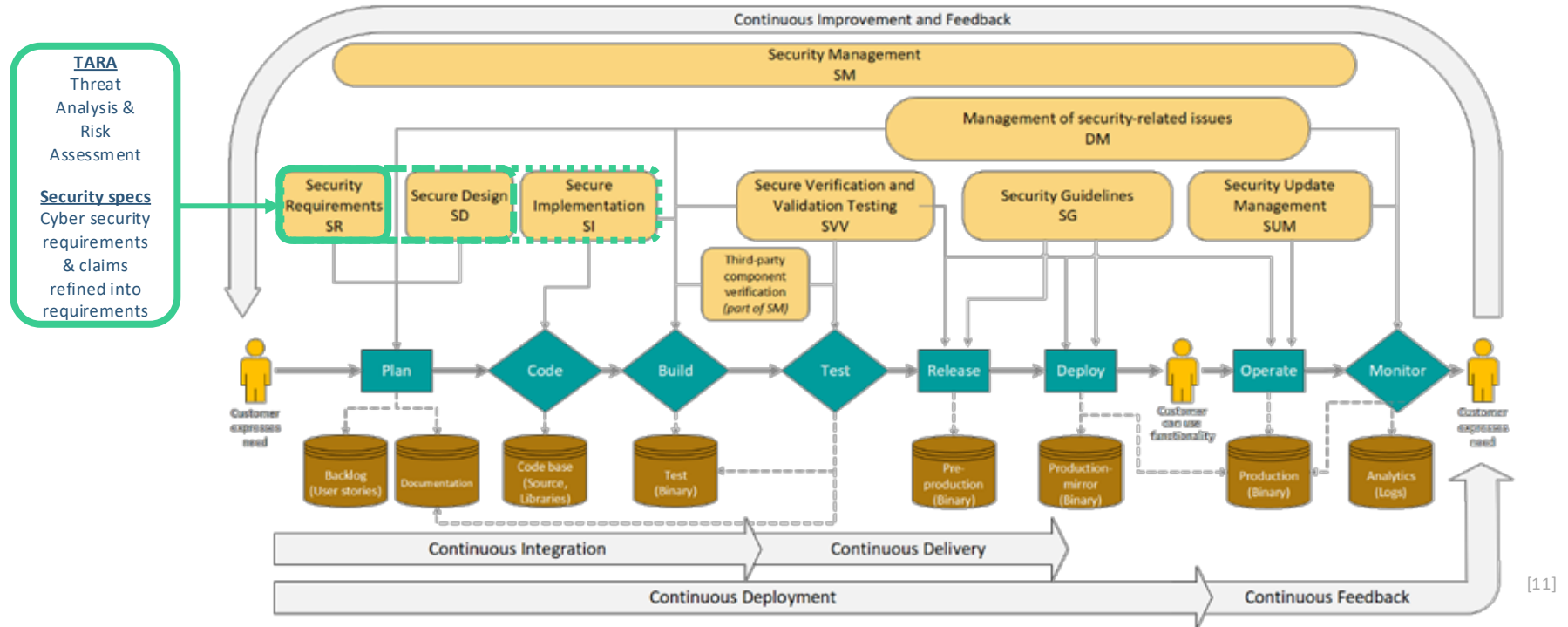
Targeted cyber security principle: Proportionality & Precautionary

- Enables proportionality by quantifying risk
- Prevents “one-size-fits-all” security
- Justifies security decisions (traceability)
- Helps balance security vs constraints
 - Performance
 - Cost
 - Usability
 - ...



<https://www.jklossner.com/>

Threat Analysis & Risk Assessment – WHY



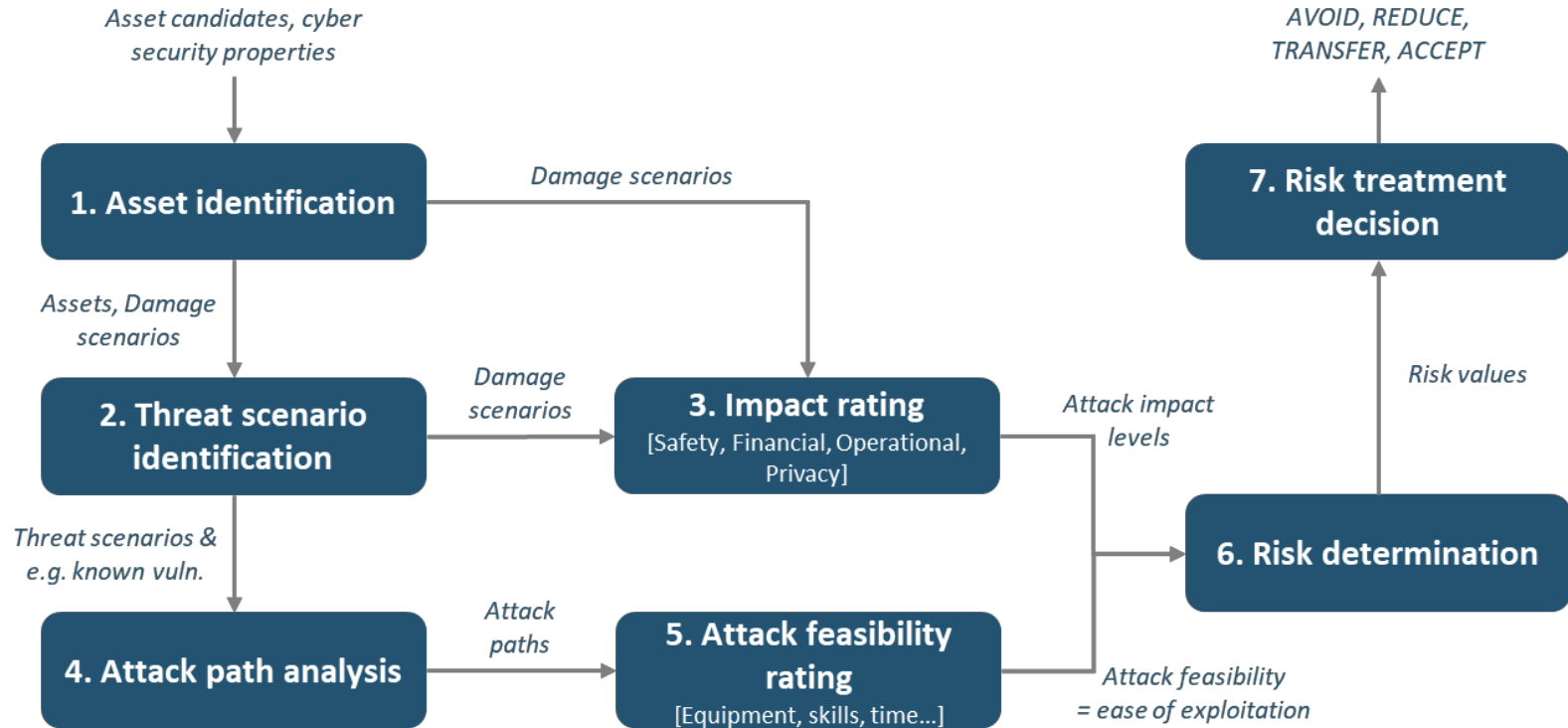
TARA Primitives – Terminology

Assets & cyber security attributes	Threat scenarios	Damage scenarios
Key components (hardware, software, data) and their security attributes (confidentiality, integrity, availability) that has a value for product / system stakeholders. <i>Examples: confidentiality of user data, integrity of new SW package...</i>	High-level & realistic attack situations describing how adversaries could target system vulnerabilities to compromise security <i>Examples: Denial-of-service of logging function, GPS Spoofing, tampered data...</i>	Impact and/or consequences of successful cyber attacks, including safety, financial, operational, and legal harm amongst other dimensions (up to company risk mgmt.) <i>Examples: Loss of personal data (PII) leading to GDPR penalty and reputational damage...</i>
Cyber security measures & controls	Vulnerabilities	Exploits / attack chains
Technical and organizational safeguards to reduce risk and protect assets from cyber threats <i>Examples: Secure boot mechanisms, Secure SW OTA deployment, SecOC over CAN...</i>	Real weaknesses in a product / system that could be exploited by a threat actor, implementing a threat scenario <i>Examples: Buffer overflows, Remote Code Execution, non-sanitized inputs handling...</i>	Step-by-step methods attackers use to leverage vulnerabilities and achieve malicious objectives. <i>Examples: Phishing campaign, credential retrieval, communication message forging...</i>

TARA Primitives – Warning

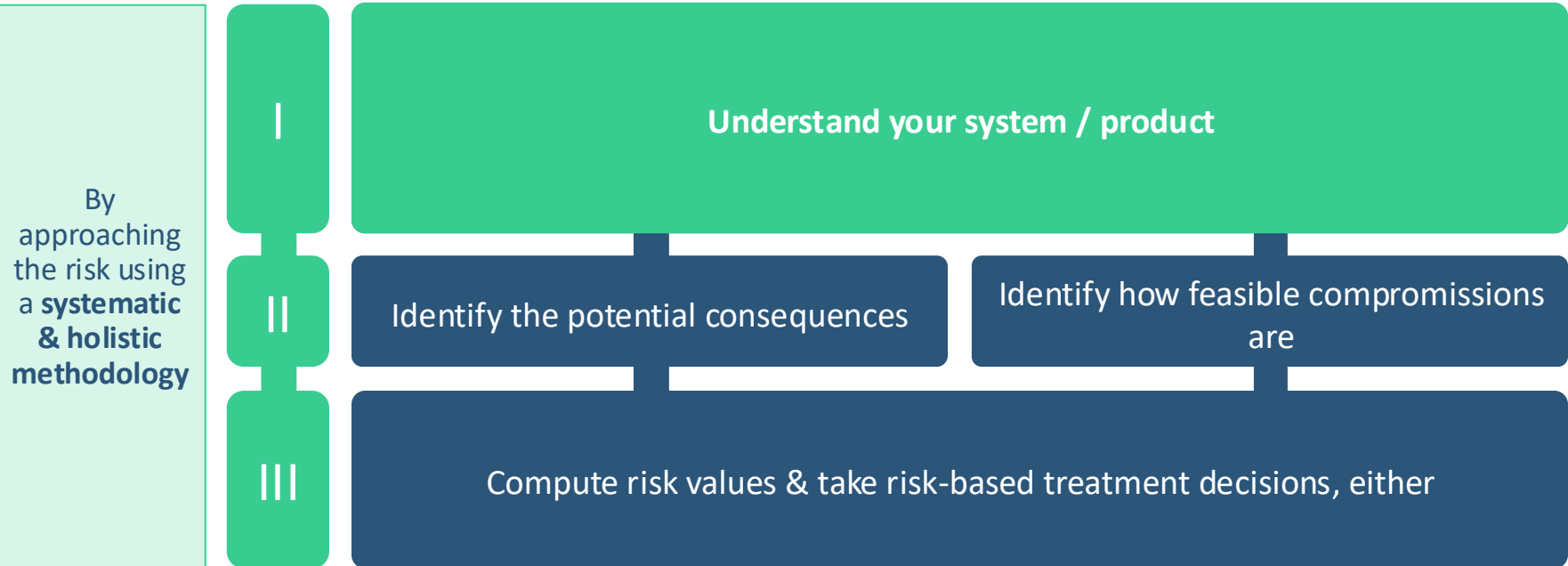
- There is multi way to do a Threat Model and Risk Assessment. This one is one example.
- It is based on ISO/SAE 21434 (automotive) and fits good for OT product (based on our own experience)
- There is many other ways to do it:
 - IEC62443 for Systems
 - NIST SP 800-82 / NIST CSF
 - ISO/IEC 27005 (More governance / infosec related)
 - CRA guidelines also give a few examples
 - ENISA Security by Design and Default Playbook
 - BSI: Technical Guideline TR-03183: Cyber Resilience Requirements for Manufacturers and Products
 - Name your own

TARA Primitives – Relationships



TARA Process – Walk through

How to identify the relevant threats, assess them using reasonable metrics and initiate the integration of such key security principles ?



TARA Process – 1st step – System Definitions

Objective: Clarify following elements to drive TARA process with relevant inputs

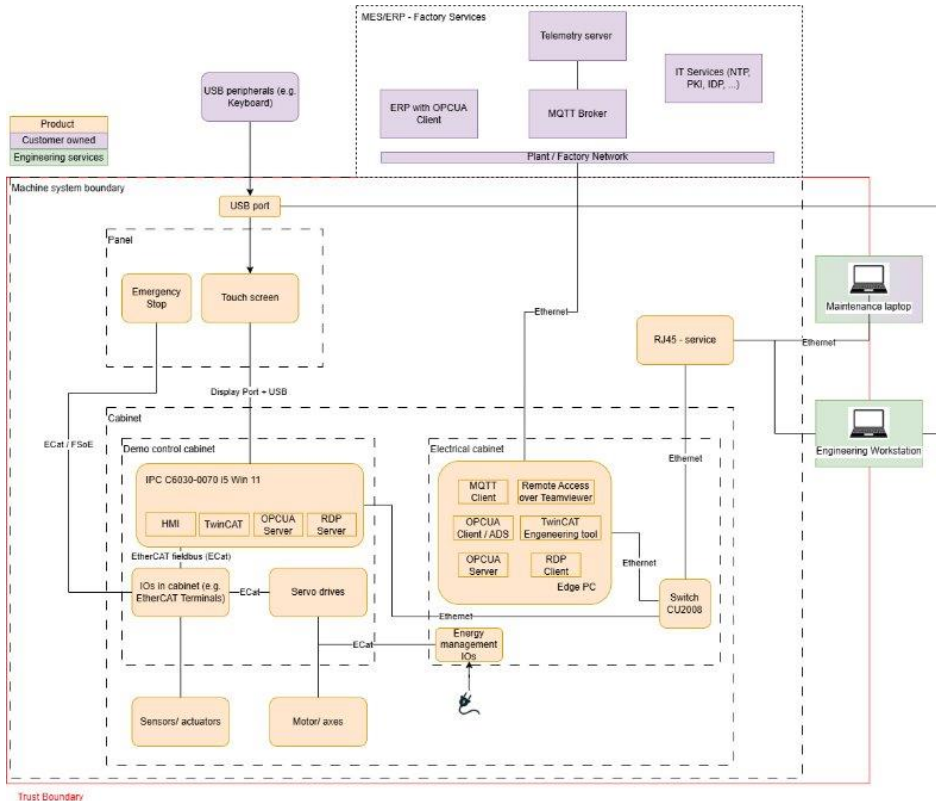
- product / system function: What are functions provided to customer and any other stakeholder during all phases of product lifecycle ?
 - Examples: sensor measurement, safe-mode enablement, system diagnostic, SW update, data logging...
- Assets & cyber security attributes relevance: What matters in the case of compromission ?
 - Examples: confidentiality of user data, integrity of SW update, availability of Safety function...
- Assumptions: What pre- / environmental / adversarial conditions impact the system / product ?
 - Examples: running in a protected / restricted environment, trained stakeholders, centralized authentication servers provided by hosting environment...
- Architecture: What are product / system sub parts ?
- communications (dataflows, technologies): What information exchanges between product / system parts & towards external parties ?
- trust boundaries: What is under company's control ?

TARA Process – 1st step – System Definitions



- Context: This CNC machine manufactures turbocharger compressor wheels, primarily for the European automotive industry. While the design is not revolutionary, research was conducted to optimize cost, reliability, and manufacturing time for each part.
- The CNC machine cell produces aluminum parts for a downstream assembly line. An Industrial PC running Windows 11 and TwinCAT 3 controls axes and I/O over EtherCAT, provides the local HMI, and hosts an OPC UA server. A gateway/edge PC bridges the machine cell to the plant network for MES integration and telemetry via MQTT. Remote access must be enabled for maintenance.

TARA Process – 1st step – System Definitions



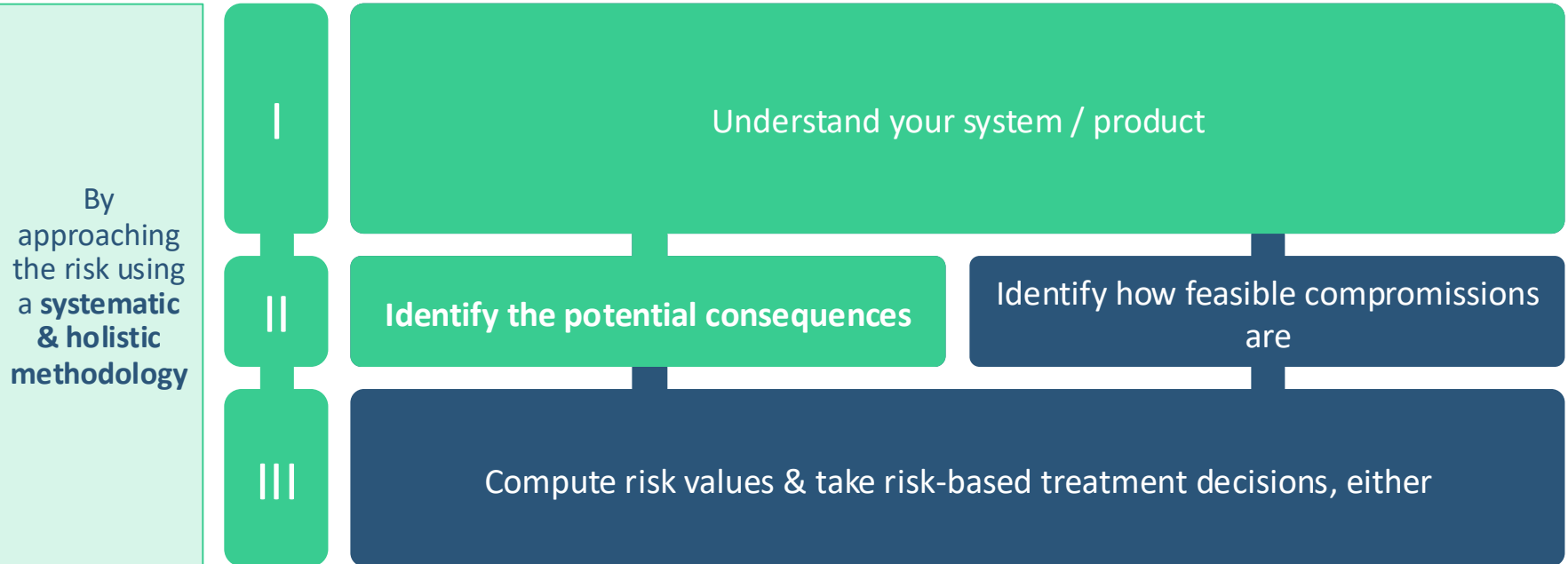
TARA Process – 1st step – Assets Definitions

Communication and interfaces				
External & Internal Ports				
id	Internal / External	Name	Functions	Remarks
I-001	External	Panel USB	Keyboard + Mouse	
I-002	External	Panel button	Emergency stop	TwinSAFE and FSoE
I-003	External	Service Ethernet	Ethernet for maintenance	
I-004	External	Edge PC Ethernet	Remote access, OPCUA Server, MQTT	Connected to plant /
I-005	Internal	EtherCAT	I/O, controls axes	
I-006	Internal	IPC Ethernet Port	OPCUA, ADS, RDP	
Externals dependencies				
id	Name	Functions	Remarks	
D-001	ERP / MES	Send program reference, parameters.	Use OPCUA client	
D-002	MQTT Broker	MQTT Broker for telemetry data		
D-003	NTP Server	Provide time to Edge and IPC	Edge PC may be used as	

 Assets description	Dataflow flow						System functions						Properties				
	Panel USB	Panel button	Service Ethernet	Edge PC Ethernet port	EtherCAT Bus	IPC Ethernet Port	Motion control	Ops management	HMI	Data transmission	Telemetry	Maintenance (update, config, remote access, ...)	Logging	Emergency Stop	C	I	A
A01 - IPC HW	x				x	x	x		x	x	x						x
A02 - Edge PC HW				x				x		x	x	x					x
A03 - IPC OS	x				x	x	x		x	x		x				x	x
A04 - Edge PC OS				x		x		x		x	x	x				x	x
A05 - IPC TwinCAT software stack					x	x	x		x	x		x				x	x
A06 - Edge PC TwinCAT software stack				x	x			x		x	x	x				x	x
A07 - Telemetry data				x							x						x
A08 - Industrial communication data				x		x	x	x	x							x	x
A09 - Remote access data				x	x	x					x						x
A10 - TwinCAT project data				x	x	x	x	x	x		x					x	x
A11 - NTP time data				x		x					x	x					x
A12 - RealTime data			x	x	x	x	x							x			x
A13 - Log data	x												x				x
A14 - Cryptographic material for communication security				x		x				x	x					x	x

TARA Process – Walk through

How to identify the relevant threats, assess them using reasonable metrics and initiate the integration of such key security principles ?



TARA Process – 2nd step (a) – Damage scenario

Damage scenarios are consequences of compromissions of cyber security properties of assets

Major cyber security properties

- Authentication – The asset must be linked with its author / editor over its entire lifecycle
- Integrity – The asset is accurate and complete (= unaltered) over its entire lifecycle.
- Confidentiality – The asset is not made available or disclosed to unauthorized individuals, entities, or processes.
- Availability – The asset must be available when it is needed

Some well-known triads:

- CIA – Confidentiality, Integrity and Availability, a model designed to guide policies for information security within an organization.
- AAA – Authentication, Authorization and Accounting, a model for a framework for intelligently controlling access to computer resources, enforcing policies, auditing usage, and providing the information necessary to bill for services. These combined processes are considered important for effective network management and security.

TARA Process – 2nd step (a) – Damage scenario

1. ASSET IDENTIFICATION				
Asset	C	I	A	Damage Scenario Description <i>[worst case]</i>
A03 - IPC OS		x		Damaging to the machine, to parts, or safety hazards.
A08 - Industrial communication data	x			Sensitive operational data, including machine state, recipes, or production parameters reveal trade secrets or critical operational information.
A08 - Industrial communication data		x		Incorrect operations, misreporting, or unsafe conditions in external systems.
A08 - Industrial communication data			x	Machine axes stop, leading to halted production, potential damage to machine or in progress parts.
A09 - Remote access data		x		Unauthorized configuration changes or machine misuse.

TARA Process – 2nd step (b) – Threat scenario

Threat scenario identification is a key intermediate step to identify relevant high-level scenario an attack may exploit to compromise assets, and therefore force the system / product to lead to damage scenario

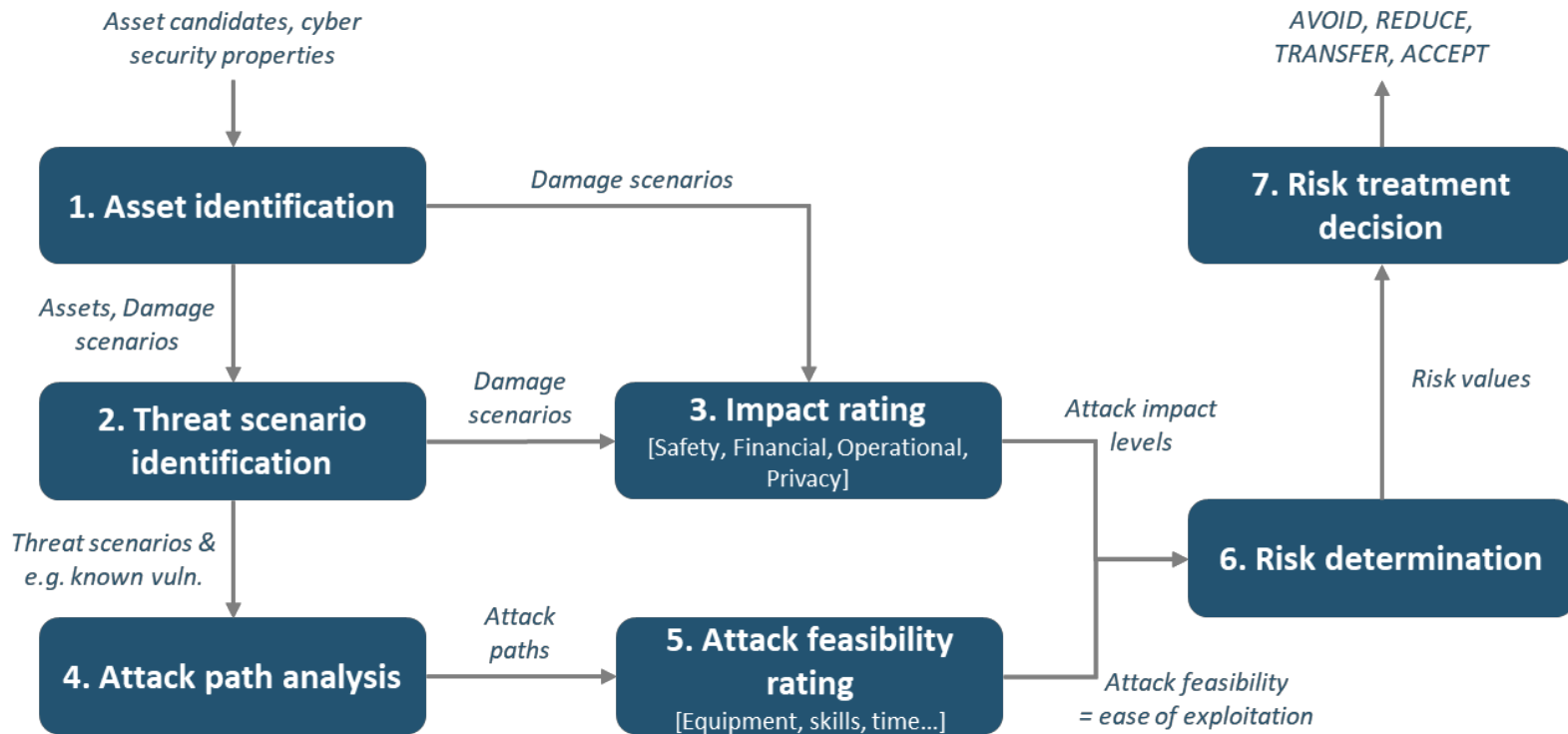
- STRIDE is an acronym. It stands for

Accr.	Threat	Desired property	Description
S	Spoofing	Authenticity	Impersonating something of someone else
T	Tampering	Integrity (CIA)	Modifying data or code
R	Repudiation	Non-repudiation	Claiming to have not performed an action
I	Information disclosure	Confidentiality (CIA)	Exposing information to someone not authorized to see it
D	Denial of service	Availability (CIA)	Deny or degrade service to users
E	Elevation of privilege	Authorization	Gain capabilities/rights without proper authorization

TARA Process – 2nd step (b) – Threat scenario

1. ASSET IDENTIFICATION					2. THREAT SCENARIO IDENTIFICATION	
Asset	C	I	A	Damage Scenario Description <i>[worst case]</i>	Threat	Threat Scenario Description
A03 - IPC OS		x		Damaging to the machine, to parts, or safety hazards.	Tampering	Malware changes OS files or drivers, altering timing, motion logic, or process parameters. Motion control executes commands incorrectly.
A08 - Industrial communication data	x			Sensitive operational data, including machine state, recipes, or production parameters reveal trade secrets or critical operational information.	Info disclosure	An attacker eavesdrops on the industrial communication between Edge PC and external systems, capturing production data or machine configurations.
A08 - Industrial communication data		x		Incorrect operations, misreporting, or unsafe conditions in external systems.	Tampering	An attacker tamper on the industrial communication between Edge PC and external systems, capturing production data or machine configurations.
A08 - Industrial communication data			x	Machine axes stop, leading to halted production, potential damage to machine or in progress parts.	Denial of service	DoS attack blocks or drops industrial communications frames, causing IPC to lose control of drives.
A09 - Remote access data		x		Unauthorized configuration changes or machine misuse.	Tampering	An attacker intercepts or hijacks the external remote access session and modifies commands or session data exchanged with the Edge PC.

TARA Primitives – Relationships



TARA Process – 2nd step (a) – Impact rating

Damage scenarios shall be assessed against potential adverse consequences for stakeholders in, at least, the independent impact categories of safety, financial, operational, and privacy (or legal)

- So-called SFOP impacts

If further impact categories are considered beyond S, F, O and P, then those categories shall be documented.

- Examples of other / more specific categories : loss of intellectual property, financial losses to business, loss of brand image or reputation

The impact rating of the damage scenario shall be determined to be one of the following: Severe, Major, Moderate or Negligible.

Impact Rating	Criteria for Financial Impact Rating
Severe	The financial damage leads to catastrophic consequences which the affected stakeholder might not overcome.
Major	The financial damage leads to substantial consequences which the affected stakeholder will be able to overcome.
Moderate	The financial damage leads to inconvenient consequences which the affected stakeholder will be able to overcome with limited resources.
Negligible	The financial damage leads to no effect, negligible consequences or is irrelevant to the stakeholder.

[1
2]

TARA Process – 2nd step (a) – Impact analysis

Example from automotive industry
[ISO/SAE 21434, annex H]

Impact Rating	Criteria for Operational Impact Rating
Severe	The operational damage leads to a vehicle not working, from non-intended operation up to the vehicle being non-operational.
Major	The operational damage leads to the loss of a vehicle function.
Moderate	The operational damage leads to partial degradation of a vehicle function or performance.
Negligible	The operational damage leads to no effect or indiscernible degradation of a vehicle function or performance.

[12]

Impact Rating	Criteria for Privacy Impact Rating
Severe	The privacy damage leads to significant or even irreversible impact to the road user. In this case, the information regarding the road user is highly sensitive and easy to link to a PII principal.
Major	The privacy damage leads to serious impact to the road user. In this case, the information regarding the road user is: a) highly sensitive and difficult to link to a PII principal, or b) sensitive and easy to link to a PII principal.
Moderate	The privacy damage leads to significant inconveniences to the road user. In this case, the information regarding the road user is: a) sensitive but difficult to link to a PII principal, or b) not sensitive but easy to link to a PII principal.
Negligible	The privacy damage leads to no effect or can create few inconveniences to the road user. In this case, the information regarding the road user is not sensitive and difficult to link to a PII principal.

[12]

Impact Rating	Criteria for Safety Impact Rating
Severe	S3: Life-threatening injuries (survival uncertain), fatal injuries
Major	S2: Severe and life-threatening injuries (survival probable)
Moderate	S1: Light and moderate injuries
Negligible	S0: No injuries

Safety impact rating criteria are taken from ISO 26262-3:2018.

[12]

TARA Process – 2nd step (a) – Impact analysis

Must be :

- Reproducible
- Trustable
- Tailored for use-case

Safety	Safety impact rating criteria are taken from ISO 26262-3:2018. Controllability according to ISO 26262-3:2018 can also be considered for calculating impact on safety, if a rationale is provided. Maybe check IEC 61508 also?	Negligible	No injury (Based on ISO26262-3)
		Moderate	Light and moderate injuries (Based on ISO26262-3)
		Major	Severe and life-threatening injuries (survival probable) (Based on ISO26262-3)
		Severe	Life-threatening injuries (survival uncertain), fatal injuries (Based on ISO26262-3)
Privacy and legislation	The "Privacy and legislation" category includes damages caused by privacy violation of stakeholders (e.g., machine owner, integrators, users) and/or violation of legislations/regulations (e.g. emissions). Privacy and legislation are merged into one parameter because privacy may be enforced through legislation and there exist legislations that are not related to privacy. Usually, such damages do not have direct injury, financial and operational dimensions. However, in certain situations, privacy and legislation violations may cause financial (e.g., fine, loss of access to certain market) and operational damages to the stakeholders. Consequently, the impact of the privacy and legislation category is relatively lower with respect to the safety and financial categories	Negligible	The privacy damage leads to no effect or can create few inconveniences to the stakeholders. In this case, the information regarding the stakeholders is not sensitive and difficult to link to a PII principal.
		Moderate	The privacy damage leads to significant inconveniences to the stakeholders. In this case, the information regarding the stakeholders is either: a) sensitive but difficult to link to a PII principal, or b) not sensitive but easy to link to a PII principal.
		Major	The privacy damage leads to serious impact to the stakeholders. In this case, the information regarding the stakeholders is either: a) highly sensitive and difficult to link to a PII principal, or b) sensitive and easy to link to a PII principal.
		Severe	The privacy damage leads to significant or even irreversible impact to the stakeholders. In this case, the information regarding the stakeholders is highly sensitive and easy to link to a PII principal.

Criteria	Criteria description	Parameter	Additional information
Financial	The "Financial" category considers all financial losses or damages that can be either direct or indirect. - Direct financial damages may include product liability issues (e.g., penalties, recalls), legislation issues (e.g., penalties due to nonconformance), product features (e.g., loss in business due to illicit activation of sellable features). - On the other hand, indirect financial damages may include damage to customer reputation, loss of market share, IP infringement, etc. Also, safety issues may contribute to financial damages. To summarize, the financial damage is the sum of direct and indirect costs for the company and the root cause may originate from any of the stakeholders	Negligible	The financial damage leads to no effect, negligible consequences or is irrelevant to the stakeholder
		Moderate	The financial damage leads to inconvenient consequences which the affected stakeholder will be able to overcome with limited resources.
		Major	The financial damage leads to substantial consequences which the affected stakeholder will be able to overcome.
		Severe	The financial damage leads to catastrophic consequences which the affected stakeholder might not overcome.
Operational	The "Operational" category includes operational damages caused by unwanted and unexpected changes in (or loss of) a end-system function. Examples of such operational damages include loss of secondary (e.g., performance optimization) functionalities of the end-system. However, in certain situations, operational damages may cause safety and financial damages. For example, operational damages in the form of loss of primary and safety-related end-system functionalities may affect safety of users and stakeholders. Consequently, the impact of the operational category on the overall impact is relatively lower with respect to the safety and financial categories	Negligible	The operational damage leads to no effect or indiscernible degradation of a end-system function or performance.
		Moderate	The operational damage leads to partial degradation of a end-system function or performance
		Major	The operational damage leads to the loss of a end-system function
		Severe	The operational damage leads to a end-system not working, from non-intended operation up to the end-system being non-operational.

[12]

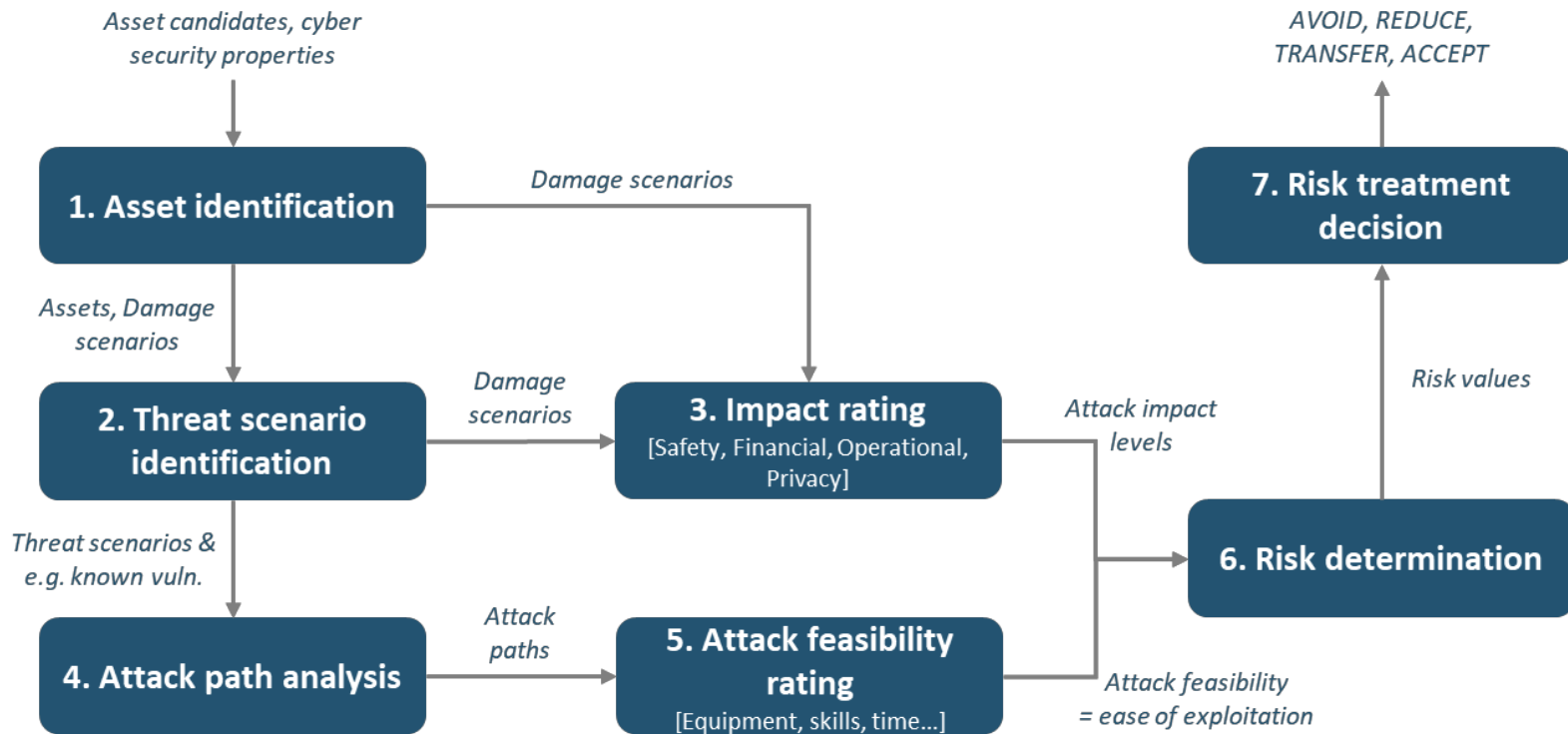
[12]

TARA Process – 2nd step (a) – Impact analysis

1. ASSET IDENTIFICATION					2. THREAT SCENARIO IDENTIFICATION	
Asset	C	I	A	Damage Scenario Description <i>[worst case]</i>	Threat	Threat Scenario Description
A03 - IPC OS		x		Damaging to the machine, to parts, or safety hazards.	Tampering	Malware changes OS files or drivers, altering timing, motion execution
A08 - Industrial communication data	x			Sensitive operational data, including machine state, recipes, or production parameters reveal trade secrets or critical operational information.	Info disclosure	An attacker commu system: configu
A08 - Industrial communication data		x		Incorrect operations, misreporting, or unsafe conditions in external systems.	Tampering	An attacker between product
A08 - Industrial communication data			x	Machine axes stop, leading to halted production, potential damage to machine or in progress parts.	Denial of service	DoS attack commu of drive
A09 - Remote access data		x		Unauthorized configuration changes or machine misuse.	Tampering	An attacker access s data ex

3. IMPACT RATING					
Financial	Operational	Privacy	Safety	Worst Impact Description	Highest Impact
Major	Moderate	Negligible	Moderate	Default are introduce in manufactured items and safety operations are removed.	Major
Moderate	Negligible	Major	Negligible	Loss of sensitive operational information, trade secrets exposure, and potential competitive or regulatory consequences.	Major
Major	Moderate	Negligible	Moderate	Incorrect production execution, mismanagement of operations, potential safety hazards	Major
Moderate	Major	Negligible	Negligible	Production is stopped until denial of service is stopped.	Major
Major	Moderate	Negligible	Moderate	Default are introduce in manufactured items and safety operations are removed.	Major

TARA Primitives – Relationships



Use case-based exercises - guidance

Part I

[in-class]

Domestic medical device

- System understanding & asset identification
- Threat scenario identification
- Impact rating

Part II

[in-class]

Domestic medical device

- Attack path analysis
- Attack feasibility rating
- Risk calculations & treatment decisions

Homework

[optional]

Professional medical device